پیوست الف — توجیه انتخاب کتابخانه‌ها

در این بخش کتابخانه‌ها و فریمورک‌های استفاده‌شده معرفی و دلیل انتخاب هرکدام به اختصار توضیح داده می‌شود.

کتابخانه	نسخه	نقش در پروژه	توجیه انتخاب
`fastapi`	x.0.162	وب‌فریم‌ورک ASGI	تایپ‌محور بودن و پشتیبانی خودکار از OpenAPI که تولید مستندات تعاملی (`docs/`) را بدون کد اضافه ممکن می‌کند. پشتیبانی بومی از فرم‌ها (برای `token/`) و JSON (برای Admin API) آن را برای پیاده‌سازی OIDC مناسب می‌کند.
`uvicorn[standard]`	x.0.54	سرور ASGI	سرور استاندارد و پرسرعت برای FastAPI. افزونهٔ `[standard]` شامل `uvloop` و `httptools` است که کارایی را در محیط‌های عملیاتی افزایش می‌دهد.
`sqlalchemy`	x.2.1	ORM و لایهٔ داده	انتزاع قابل حمل میان SQLite و Postgres. امکان استفاده از `TypeDecorator` (برای حل مشکل تاریخ در SQLite) و Core Operations (برای درج در جدول‌های واسط) را فراهم می‌کند.
`pydantic-settings`	x.2.16	مدیریت تنظیمات	API رسمی Pydantic v2 برای بارگذاری متغیرهای محیطی از `.env` با تبدیل نوع خودکار. از ورود مقادیر نادرست به کد جلوگیری می‌کند.
`pyjwt[crypto]`	x.2.15	امضا و اعتبارسنجی JWT	کتابخانهٔ استاندارد پایتون برای JWT. افزونهٔ `crypto` وابستگی `cryptography` را نصب می‌کند که برای الگوریتم نامتقارن RS256 ضروری است.
`argon2-cffi`	x.23.1	هش رمز عبور	پیاده‌سازی الگوریتم Argon2id که در توصیه‌نامهٔ OWASP (۲۰۲۴) به‌عنوان بهترین گزینه معرفی شده است. مقاومت بالایی در برابر حملات مبتنی بر GPU دارد.
`python-multipart`	0.0.33	پردازش فرم‌ها	پیش‌نیاز اجباری FastAPI برای دریافت داده‌های `application/x-www-form-`

کتابخانه	نسخه	نقش در پروژه	توجیه انتخاب
			`urlencoded` . بدون آن، endpointهای `token/` و فرم ورود HTML کار نمی‌کنند.
`jinja2`	x.3.1	موتور قالب	برای رندر امن فرم ورود HTML (`/login`). استفاده از قالب به‌جای ساخت رشته‌های HTML با f-string از آسیب‌پذیری XSS جلوگیری می‌کند.
`httpx`	x.0.28	کلاینت HTTP	هم توسط `TestClient` در FastAPI استفاده می‌شود و هم در اسکریپت‌های دمو برای شبیه‌سازی رفتار مرورگر و فراخوانی سرورها به کار می‌رود.
`pytest`	x.8.4	چارچوب تست	استاندارد صنعت پایتون. قابلیت fixtureها و dependency injection آن، تست لایه‌های مختلف (مدل، سرویس، API) را بسیار ساده می‌کند.
`pytest-asyncio`	x.0.26	افزونهٔ تست	برای پشتیبانی از تست‌های همگام (async) که در تست مسیرهای وب و دیتابیس به کار می‌آید.

پیوست ب — منابع و استانداردهای استفاده‌شده

۱. استانداردهای پروتکل

- **RFC 6749** — The OAuth 2.0 Authorization Framework (مبنای جریان Auth Code و ساختار خطاها).
- **RFC 7636** — Proof Key for Code Exchange (PKCE) (مبنای پیاده‌سازی `code_challenge` و `code_verifier`).
- **RFC 7662** — OAuth 2.0 Token Introspection (مبنای `/introspect` endpoint).
- **RFC 7009** — OAuth 2.0 Token Revocation (مبنای `/revoke` endpoint).

- JSON Web Token (JWT) — **RFC 7519** (مبنای claimهای `exp` ، `aud` ، `sub` ، `iss`).
- JWS — **RFC 7515 / 7517** و JWK (مبنای ساختار امضا و تولید JWKS).
- **OpenID Connect Core 1.0** — مبنای تولید ID Token و `/userinfo` endpoint.
- **OpenID Connect Discovery 1.0** — مبنای ساختار فایل `./-well-known/openid-configuration`.

۲. توصیه‌نامه‌های امنیتی

- **OWASP Password Storage Cheat Sheet (2024)** — مرجع انتخاب پارامترهای هش Argon2id.
- **OWASP Authorization Cheat Sheet** — مرجع تفکیک خطاهای احراز هویت (401) از خطاهای مجوزدهی (403).

۳. مستندات رسمی کتابخانه‌ها

- مستندات رسمی SQLAlchemy 2.x (بخش‌های `TypeDecorator` ، `selectinload` ، `populate_existing`).
- مستندات رسمی FastAPI (بخش‌های Dependency Injection و TestClient).
- مستندات رسمی PyJWT (بخش‌های الگوریتم‌های RSA و PyJWKClient).
- مستندات رسمی Pydantic-Settings و Argon2-cffi.

۴. منابع معماری

- **Robert C. Martin** — *Clean Architecture* (چارچوب نظری برای تفکیک لایه‌ها و اصول SOLID که در فصل ۲ و ۹ به آن اشاره شد).
- **Martin Fowler** — *Patterns of Enterprise Application Architecture* (الگوی Service Layer).
- مستندات Keycloak و Duende IdentityServer (به‌عنوان مرجع رفتاری برای مفاهیمی مانند Realm، Client و Scope؛ بدون استفاده از کد یا وابستگی اجرایی).